

# Week 13: Lab Activities & Final Penetration Testing Project

**Important Note: This lab is only for your awareness, so just perform it for your practice, and no need to submit any report or document for this lab to your instructor.**

---

## Lab 1: Phishing Campaign with Social Engineering Toolkit (SET)

### Objectives

- Understand phishing attack mechanics
- Learn Social Engineering Toolkit fundamentals
- Demonstrate credential harvesting in controlled environment
- Develop awareness of phishing indicators

### Prerequisites

- Linux-based lab environment (Kali Linux recommended)
- Virtual network isolated from internet
- Lab partner for authorized testing consent

### Step-by-Step Instructions

#### Step 1: Environment Setup

1. Open terminal in Kali Linux
2. Verify SET is installed:

```
which setoolkit
```

If not installed: `sudo apt-get install set`

3. Launch SET with root privileges:

```
sudo setoolkit
```

4. Accept the disclaimer regarding authorized testing only

#### Step 2: Create a Simulated Organization

Before launching a phishing attack, establish realism by identifying a target:

1. Review the provided "Acme Corp" organizational chart (provided separately)
2. Note the following employees:

- Bob Johnson (CEO)
- Sarah Chen (IT Director)
- Mike Williams (Finance Manager)
- Amy Rodriguez (HR Specialist)

1. Collect OSINT (Open Source Intelligence) on the mock organization:

- Review the company website at <http://target-company.local>
- Note email format: [firstname.lastname@target-company.local](mailto:firstname.lastname@target-company.local)
- Identify recent news: "Company migrating to new email system"

### Step 3: Design the Phishing Email

Return to SET menu and select **Option 1: Social Engineering Attacks** → **Option 2: Website Attack Vectors**

1. Choose **Option 3: Credential Harvester Attack Method**
2. Choose **Option 2: Site Cloner** (clone legitimate internal login page)
3. Enter target URL for cloning:

`http://target-company.local/mail/login.html`

4. SET will download and clone the page locally
5. Choose **Option 2: Apache Server** to serve the cloned page
6. Set listening IP address to your lab machine: `192.168.100.50`

### Step 4: Create Phishing Email Content

Using the context gathered:

#### Email Draft:

Subject Line: **"URGENT: Email System Migration - Action Required by EOD"**

From: [no-reply@target-company.local](mailto:no-reply@target-company.local) (spoofed)

Body:

Dear Staff,

As announced in our recent company communications, we are migrating to our new email system on [DATE]. To ensure

uninterrupted service, please verify your credentials on the new platform before the migration.

Click here to verify credentials:  
<http://192.168.100.50/login.html>

This link will expire at 5:00 PM today.

IT Department  
Target Company

## Analysis Points:

- Uses urgency (deadline)
- Spoofed from legitimate-looking sender
- Leverages recent company news
- Creates fear of service disruption

## Step 5: Deploy the Phishing Email

1. In lab environment, send test email to lab partner using `sendmail`:

```
sendmail -f no-reply@target-company.local testuser@target-company.local <phishing_email.txt
```

2. Have lab partner receive and read the email
3. Instruct them to click the link in the email

## Step 6: Capture Credentials

1. Lab partner enters their username and password in the cloned login page
2. Monitor SET console output, credentials will be captured and displayed:

```
[*] Username: [testuser]  
[*] Password: [testpassword]
```

3. Screenshot the captured credentials from SET console

## Step 7: Analysis and Documentation

Create a lab report documenting:

### 1. Email Analysis:

- How many elements from the lecture's psychological principles are present? (Urgency, authority, social proof, etc.)
- What indicators of compromise does the email display?
- How could this email be detected by email filtering?

### 1. Results:

- Credential capture success (yes/no)
- Time from email sent to credential capture
- What information is exposed in captured credentials?

### 1. Defense Mechanisms:

- How would MFA prevent this attack's success?
- What email authentication (SPF/DKIM/DMARC) would catch this?
- How should employees identify this phishing attempt?

## Step 8: Cleanup

1. Stop Apache server: `sudo systemctl stop apache2`
2. Remove cloned pages from web root
3. Delete sent emails from mail logs

---

# Lab 2: Spear Phishing Email Design & A/B Testing

## Objectives

- Develop targeted phishing emails
- Understand personalization in social engineering
- Conduct controlled A/B testing
- Analyze effectiveness metrics

## Prerequisites

- Lab 1 completion recommended
- Email testing platform (Gophish or similar)
- Understanding of target organization structure

## Step-by-Step Instructions

### Step 1: Target Intelligence Gathering

1. Assign target persona from organization:
  - Name: Mike Williams
  - Title: Finance Manager
  - Department: Finance
  - Responsibilities: Payment approval, vendor management

1. Gather intelligence on this individual:

- Review LinkedIn profile (mock version provided)
- Note recent activity: "Just returned from vacation"
- Professional connections: Works with vendors
- Education: Graduated from State University

1. Identify vulnerability:

- Finance managers process payments routinely
- Post-vacation: Likely to have backlog of emails
- Urgency: Financial deadlines are common
- Authority: Likely to trust vendors and executives

## Step 2: Create Multiple Phishing Variants

Design three versions with different psychological approaches:

### Version A: Authority + Urgency

Subject: URGENT PAYMENT REQUIRED - Vendor Invoice #2847  
From: accounting@[vendor-company].com  
Body: Mike,

Our system shows payment for invoice #2847 (\$15,400) is overdue. Please approve payment immediately via this link: [malicious-link]

To avoid service interruption, action required by EOD.

Finance Team

### Version B: Reciprocity + Social Proof

Subject: Account Verification - Standard Annual Process  
From: finance-compliance@target-company.local  
Body: Mike,

As part of our annual compliance verification, please confirm your account details. Other team members have already completed this process: [names].

Click here to verify: [malicious-link]

Finance Compliance

### Version C: Scarcity + Authority (Simulated Executive)

Subject: CONFIDENTIAL - Quick Approval Needed  
From: bob.johnson@target-company.local (spoofed)  
Body: Mike,

I need your quick approval on an emergency vendor payment (\$8,500) before end of business today. Details are attached.

Approve here: [malicious-link]

Please keep this confidential.

Bob

### Step 3: Setup Phishing Testing Platform

Using Gophish (open-source phishing framework):

1. Download and install:

```
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
unzip gophish-v0.12.1-linux-64bit.zip
chmod +x gophish
```

2. Launch Gophish:

```
./gophish
```

3. Access admin panel: <https://localhost:3333>

4. Default credentials: admin/gophish (change immediately)

5. Create new campaign:

- Name: "Finance Department A/B Test"
- Email template: Upload Version A
- Landing page: Credential capture form
- Target group: Create email list with test recipients

### Step 4: Deploy Phishing Variants

1. Create three identical campaigns, each using one email version:

- Campaign A: Authority variant (Send to subset of 25 recipients)
- Campaign B: Reciprocity variant (Send to subset of 25 recipients)
- Campaign C: Scarcity variant (Send to subset of 25 recipients)

1. Record deployment time and date

2. Monitor Gophish dashboard in real-time:

- Email delivery status
- Open rates (when recipient opens email)
- Click rates (when recipient clicks malicious link)
- Data submission (when credential form submitted)

## Step 5: Collect Metrics

Wait 24 hours. Collect data from each variant:

| Metric               | Version A | Version B | Version C |
|----------------------|-----------|-----------|-----------|
| Emails Sent          | 25        | 25        | 25        |
| Delivered            |           |           |           |
| Opened               |           |           |           |
| Clicked              |           |           |           |
| Credentials Captured |           |           |           |
| Open Rate (%)        |           |           |           |
| Click Rate (%)       |           |           |           |
| Conversion Rate (%)  |           |           |           |

## Step 6: Analysis

Create a comparative analysis document addressing:

### 1. Which variant performed best? Why?

- Which psychological principle was most effective?
- Did timing, subject line, or body content matter most?

### 1. Unexpected results:

- Why did certain emails perform differently than expected?
- Were there demographic differences in susceptibility?

### 1. Defenses:

- How could Gophish's presence be detected?
- What email authentication would prevent spoofed "From" headers?
- How would user awareness training change results?

### 1. Real-world application:

- How does controlled A/B testing help security professionals?

- What ethical boundaries are important when conducting this in real organizations?
- 

## Lab 3: Credential Harvesting & Post-Exploitation Access

### Objectives

- Understand how harvested credentials enable network compromise
- Demonstrate lateral movement using stolen credentials
- Document impact of successful phishing
- Practice ethical containment

### Prerequisites

- Labs 1-2 completion
- Access to vulnerable lab network
- Credentials harvested from previous labs

### Step-by-Step Instructions

#### Step 1: Simulate Network Environment

Your lab instructor provides credentials harvested in Labs 1-2. DO NOT use real credentials outside of this lab.

#### Mock Harvested Credentials:

- Username: mike.williams
- Password: MyP@ss123!
- Domain: TARGET-COMPANY.LOCAL

#### Step 2: Initial Access

Attempt to use harvested credentials to access network services:

##### 1. Email Access via WebMail:

Open browser to: `https://mail.target-company.local/owa`  
Login with harvested credentials

##### 2. Document what you can access:



- Past emails (potential confidential information)
  - Calendar events (meeting details, attendees)
  - Contacts list
  - Shared resources
2. **Take screenshot** showing successful email access

### Step 3: Lateral Movement

From compromised email account, identify other systems to access:

#### 1. File Share Access:

In file explorer, navigate to: \\fileserver01\finance  
Use harvested credentials when prompted

#### 2. Document accessible shares:

- Department budget files
- Vendor information
- Financial reports
- Payroll data

#### 2. VPN Access Attempt:

Connect to VPN client  
Enter credentials: mike.williams  
Password: MyP@ss123!

#### 4. If successful, document:

- Internal network access
- Systems now reachable
- Potential for further compromise

### Step 4: Data Exfiltration Simulation

Demonstrate what an attacker could accomplish:

#### 1. Identify sensitive files accessed in Step 3:

- Budget spreadsheets
- Vendor contracts
- Employee information

#### 1. Create a list documenting:

- File names and locations
- Sensitivity level (Public, Internal, Confidential, Restricted)
- Potential business impact if compromised

1. **DO NOT actually exfiltrate data** - document intent only

## Step 5: Privilege Escalation Attempts

Attempt to gain higher-level access:

1. Check current user permissions:

```
whoami /groups
whoami /priv
```

2. Document if user is local admin (likely not; most users shouldn't be)
3. Identify potential escalation paths:

- Unpatched system vulnerabilities
- Misconfigured permissions
- Weak file permissions on sensitive binaries

2. Attempt privilege escalation (if authorized and safe in lab):

For Windows: CheckPriv or Exploit Suggester  
 For Linux: sudo -l (check if user can run privileged commands)

## Step 6: Persistence Mechanisms

Demonstrate how attackers maintain access:

1. **Password Change Prevention:**

- Would changing the password at <https://idm.target-company.local> lock you out?
- Document how an attacker might prevent legitimate user from regaining account access

1. **Account Reconnaissance:**

- Check if secondary accounts can be created
- Check if service accounts with persistent access exist
- Document any system accounts without proper permissions controls

1. **Session Persistence:**

- Note how long WebMail sessions remain active
- Identify if VPN session can be used to re-authenticate

## Step 7: Cleanup & Incident Response

Immediately contain the simulated compromise:

1. **Notify Lab Instructor** (simulating incident response team)
2. **Change Password:**

- Access <https://idm.target-company.local>
- Change password to: NewSecureP@ss456!

1. **Review Access Logs:**

Check: Security Event Viewer > Logon Events  
Document: Successful logins with harvested credential  
Time: [timestamp]  
Source IP: [your lab IP]

4. **Disable Account (Instructor will reset):**

- Contact IT to temporarily disable account pending investigation
- Document how quickly compromise was identified

## Step 8: Documentation

Create incident report addressing:

1. **Attack Timeline:**

- 14:30: Phishing email sent
- 14:45: User clicked malicious link
- 14:47: Credentials captured
- 14:50: Attacker logs in to webmail
- [Additional timestamps for lateral movement, file access, etc.]

1. **Compromise Scope:**

- What systems were accessed?
- What data was viewed?
- Who else might have been affected?

1. **Impact Assessment:**

- CVSS severity rating for compromise
- Financial/reputational damage estimate
- Regulatory implications

1. **Root Cause:**

- Phishing email bypassed filtering
- User fell for social engineering
- System allowed lateral movement via stolen credentials

**1. Remediation:**

- MFA would have prevented account access despite credential theft
  - Network segmentation would have blocked lateral movement
  - Email authentication (DMARC) would have prevented spoofing
- 

## Lab 4: USB Drop Attack & Physical Security Testing

### Objectives

- Understand physical social engineering effectiveness
- Test organizational response to found devices
- Demonstrate hygiene risks of external USB media
- Document findings professionally

### Prerequisites

- Labs 1-3 completion
- Physical lab environment with multiple staff
- USB devices for testing (pre-loaded by instructor)
- Approval for physical testing

### Step-by-Step Instructions

#### Step 1: Prepare Testing Environment

- 1. Obtain USB Testing Devices** (provided by instructor):
  - Device 1: Pre-loaded with benign tracking software
  - Device 2: Contains no actual malware, only monitoring capability
  - Label: "Confidential - Employee Compensation H2-2025"
- 1. Document Testing:**
  - Create testing log: Date, location, USB serial number
  - Photograph devices before deployment
  - Note where devices are placed

#### Step 2: Deploy USB Devices

Strategically place USB drives in three locations:

### **Location 1: Parking Lot**

- Place USB near employee parking area
- Label: "Found USB - Company Confidential"
- Record: Time deployed, exact location, GPS coordinates

### **Location 2: Common Area**

- Place USB in break room, common hallway, or reception
- Position near walkway for discovery
- Record: Time, location, nearby foot traffic

### **Location 3: Reception/Security**

- Place USB where security personnel will find it
- Approach: "Found this in the parking lot"
- Record: Time, location, security response

### **Step 3: Monitor Engagement**

The USB devices contain tracking software that logs when they're plugged in:

#### **1. Instructor Dashboard** shows in real-time:

- When device was connected
- What computer accessed the device
- Files accessed or copied
- System information from connected device

#### **1. Monitor Data:**

- Device 1 Results: [# systems connected, time to connection, files accessed]
- Device 2 Results: [# systems connected, time to connection, files accessed]
- Device 3 Results: [# systems connected, time to connection, files accessed]

### **Step 4: Assess Organizational Response**

Did the organization respond appropriately?

#### **1. Did anyone report the USB to IT/Security?**

- Yes/No
- Time lag before reporting
- Who reported it? (Department)

1. **Did security personnel quarantine the device?**

- Yes/No
- What actions were taken?
- Was there analysis of the device?

1. **Did anyone plug the device in before reporting?**

- Yes/No
- How many systems connected?
- What data was accessible?

**Step 5: Documentation & Analysis**

Create a physical security test report:

1. **Executive Summary:**

- Number of USB devices deployed: 3
- Number connected to network: [X]
- Number reported to security: [Y]
- Effectiveness rating: [X/3]

1. **Location-Specific Findings:**

**Parking Lot Device:**

- Time to discovery: [X minutes]
- Time to network connection: [Y minutes]
- Reporter identification: [Name/Department]
- Actions taken: [Description]

**Common Area Device:**

- Time to discovery: [X minutes]
- Connection status: [Connected/Not connected]
- Reporter: [Yes/No]
- Follow-up actions: [Description]

**Reception Device:**

- Response time: [X minutes]
- Security personnel awareness: [High/Medium/Low]
- Chain of custody: [Proper/Improper]

1. **Risk Assessment:**

- How many systems were compromised? [X]
- What data was exposed? [List]
- How many credentials could be captured? [X]
- Estimated damage if malicious payload: [Description]

#### 1. Recommendations:

- Endpoint security: Disable USB ports or implement USB whitelist
- User awareness: Train employees never to plug in found devices
- Physical security: Ensure found devices are immediately reported to security
- Incident response: Develop USB drop response procedures

---

## Final Project: Comprehensive Penetration Testing Report

### Objectives

- Conduct full-scope penetration test
- Document findings professionally
- Deliver actionable remediation roadmap
- Demonstrate mastery of course concepts

### Assignment Overview

Your team will conduct a simulated penetration test against a fictional organization ("BadSecure Corp") and produce a professional report suitable for C-level executives and technical teams.

### Project Scope

#### In-Scope:

- Company network: 192.168.100.0/24
- Web application: <https://app.badsecure.local>
- Wireless network: BadSecure-Guest SSID
- Physical security testing: Main office building
- Social engineering: Staff of 50 employees

#### Out-of-Scope (Prohibited):

- Do not disrupt business operations
- Do not access production databases beyond demonstrating access
- Do not download personal files unrelated to testing

- Do not conduct social engineering on individuals without written consent

### **Rules of Engagement:**

- Testing period: Week 13 (3 lab sessions + 4 hours homework)
- Timeframe: 9:00 AM - 4:00 PM only
- Contacts: [Instructor email] for emergencies
- Scope change requires written approval

### **Deliverables**

#### **1. Executive Summary Report (1-2 pages)**

Audience: CEO, CTO, Board Members

Content:

- Business context and testing scope
- High-level risk assessment (# Critical, High, Medium findings)
- Financial impact estimate
- Key recommendations (Phase 1 actions)
- Remediation timeline and estimated costs

### **Example Structure:**

#### EXECUTIVE SUMMARY

BadSecure Corp engaged us to conduct a comprehensive penetration test of its network, web applications, and physical security. Testing was conducted over [dates] and encompassed [scope].

#### FINDINGS SUMMARY:

- Critical Vulnerabilities: 3
- High-Severity Issues: 7
- Medium-Severity Issues: 12

#### KEY FINDINGS:

1. SQL injection in login form allows unauthenticated database access
2. Weak password policies enable credential compromise via phishing
3. Physical access controls ineffective; unrestricted network access possible

#### FINANCIAL IMPACT:

- Potential data breach cost: \$2.3M (based on 50K customer records)
- Regulatory fines (GDPR): Up to €1.8M
- Reputational damage: Estimated customer loss 20%

#### RECOMMENDED IMMEDIATE ACTIONS (Phase 1 - 30 days):

1. Patch SQL injection in login form (Critical)
2. Deploy multi-factor authentication for all critical systems
3. Implement physical access controls



## 2. Detailed Technical Findings Report (8-12 pages)

Audience: Security team, system administrators, developers

Content for each vulnerability:

- **Title & ID:** Unique identifier
- **Severity:** CVSS v3.1 score with reasoning
- **Description:** What the vulnerability is, technical details
- **Evidence:** Screenshots, logs, proof-of-concept output
- **Impact:** What an attacker could accomplish
- **Root Cause:** Why does this vulnerability exist?
- **Remediation:** Step-by-step fix instructions
- **Testing Procedure:** How to verify fix is effective

### Example Finding:

FINDING ID: APP-001

Title: SQL Injection in User Login Form

Severity: Critical (CVSS 9.8)

Component: Web application login portal

#### DESCRIPTION:

The login form at <https://app.badsecure.local/login.php> does not properly sanitize user input in the username field. An attacker can inject SQL code to bypass authentication.

#### PROOF OF CONCEPT:

Input: admin' OR '1'='1' --

Result: Authentication bypass; access granted without password

#### IMPACT:

- Authentication bypass for all users
- Unauthorized access to application
- Potential database manipulation
- Customer data theft

#### REMEDIATION:

1. Use parameterized queries (prepared statements)
2. Implement input validation on client and server side
3. Use ORM frameworks that prevent SQL injection
4. Apply principle of least privilege to database accounts

#### TESTING:

- Retest with various SQL injection payloads
- Verify authentication requires valid credentials
- Check error messages don't reveal database structure

## 3. Remediation Roadmap (1 page)

Timeline and prioritization:

PHASE 1 (Immediate - 0-30 days): CRITICAL

- Patch SQL injection vulnerability
- Deploy MFA for all staff
- Change all default passwords
- Estimated effort: 80 hours
- Estimated cost: \$8,000

PHASE 2 (1-3 months): HIGH PRIORITY

- Implement web application firewall
- Conduct security awareness training
- Deploy endpoint protection
- Estimated effort: 120 hours
- Estimated cost: \$15,000

PHASE 3 (3-6 months): MEDIUM PRIORITY

- Implement network segmentation
- Deploy SIEM for monitoring
- Establish incident response procedures
- Estimated effort: 200 hours
- Estimated cost: \$25,000

PHASE 4 (Ongoing): CONTINUOUS IMPROVEMENT

- Monthly vulnerability scanning
- Quarterly penetration testing
- Annual security training
- Security posture metrics tracking

## 4. Appendices

- Technical tool output (Nessus scans, Burp Suite findings)
- Network diagram showing tested systems
- Proof-of-concept code (sanitized, no real credentials)
- Methodology documentation
- Scope matrix (what was tested)

## Grading Rubric (2% of final grade = 100 points total)

### Content Quality (40 points)

| Score | Executive Summary                                                                                      | Technical Findings                                                                         | Remediation                                                              |
|-------|--------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| 10    | Clear, executive-appropriate language; business impact clearly articulated; actionable recommendations | Detailed, accurate technical analysis; multiple testing methods used; appropriate evidence | Prioritized timeline; realistic effort estimates; clear success criteria |
| 8     | Professional language; findings summarized; recommendations                                            | Good technical detail; findings validated; mostly appropriate                              | Timeline provided; effort estimates present; mostly                      |

| Score | Executive Summary                                                        | Technical Findings                                                  | Remediation                                                     |
|-------|--------------------------------------------------------------------------|---------------------------------------------------------------------|-----------------------------------------------------------------|
|       | provided                                                                 | evidence                                                            | realistic                                                       |
| 6     | Generally clear; some overly technical sections; recommendations present | Adequate technical detail; limited validation; some evidence        | Timeline present; effort estimates rough; somewhat realistic    |
| 4     | Some unclear sections; limited findings summary                          | Minimal technical detail; limited validation; insufficient evidence | Timeline vague; effort estimates missing; unrealistic in places |
| 0     | Unclear, non-professional; no recommendations                            | Minimal technical content; no validation; no evidence               | No timeline; no effort estimates                                |

### Completeness of Testing (30 points)

| Score | Web App                                                                       | Network                                                     | Physical                                                          | Social Eng                                                                   |
|-------|-------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------------------------------|------------------------------------------------------------------------------|
| 30    | Comprehensive testing; multiple vulnerabilities identified; thorough analysis | Full scope tested; multiple tools used; good documentation  | All areas tested; proper procedures followed; findings documented | Phishing successful; physical access tested; credential capture demonstrated |
| 24    | Good coverage; several vulnerabilities found; adequate analysis               | Most systems tested; multiple tools; adequate documentation | Most areas tested; procedures mostly followed; findings present   | Most aspects tested; some successes; adequately documented                   |
| 18    | Basic testing; some vulnerabilities found; limited analysis                   | Partial scope; limited tools; basic documentation           | Some testing; procedures partially followed; findings present     | Basic testing; limited successes; minimal documentation                      |
| 12    | Minimal testing; few vulnerabilities; poor analysis                           | Limited scope; few tools; poor documentation                | Minimal testing; procedures not followed; limited findings        | Minimal testing; unsuccessful; poor documentation                            |

| Score | Web App    | Network    | Physical   | Social Eng |
|-------|------------|------------|------------|------------|
| 0     | No testing | No testing | No testing | No testing |

### Professional Documentation (20 points)

| Score | Organization                                        | Grammar/Spelling                                          | Visual Aids                                    | Citations                                        |
|-------|-----------------------------------------------------|-----------------------------------------------------------|------------------------------------------------|--------------------------------------------------|
| 20    | Logical structure; easy to navigate; clear sections | No errors; professional tone; consistent formatting       | Charts, diagrams, screenshots; well-integrated | Proper attribution of methodology and references |
| 16    | Good structure; mostly navigable; clear sections    | Few errors; mostly professional; consistent               | Some visual aids; adequate integration         | Most citations present                           |
| 12    | Adequate structure; navigable; section labels clear | Several errors; professional in places; mostly consistent | Limited visual aids; minimal integration       | Some citations present                           |
| 8     | Poor structure; hard to navigate; unclear sections  | Many errors; informal tone; inconsistent                  | No visual aids                                 | Few citations                                    |
| 0     | No clear structure; difficult to read               | Numerous errors; unprofessional                           | No visual aids                                 | No citations                                     |

### Professional Conduct (10 points)

| Score | Authorization                                                            | Ethics                                                          | Evidence Handling                                                   | Communication                                                        |
|-------|--------------------------------------------------------------------------|-----------------------------------------------------------------|---------------------------------------------------------------------|----------------------------------------------------------------------|
| 10    | Clear RoE documented; stayed within scope; proper authorization obtained | No unauthorized access; appropriate restraint; no actual damage | Proper evidence collection; no data exfiltration; clean containment | Regular status updates; professional communication with stakeholders |
| 8     | RoE mostly clear; mostly stayed in                                       | Generally ethical; minor overreach;                             | Generally proper; minimal issues;                                   | Generally regular communication;                                     |

| Score | Authorization                                                 | Ethics                                                | Evidence Handling                                               | Communication                                |
|-------|---------------------------------------------------------------|-------------------------------------------------------|-----------------------------------------------------------------|----------------------------------------------|
|       | scope; authorization obtained                                 | no damage                                             | adequate cleanup                                                | mostly professional                          |
| 6     | RoE unclear; some scope creep; authorization questionable     | Some ethical concerns; some overreach; no damage      | Some improper collection; some evidence issues; partial cleanup | Limited communication; somewhat professional |
| 4     | RoE missing; scope unclear; minimal authorization             | Ethical concerns; significant overreach; minor damage | Improper collection; evidence loss; inadequate cleanup          | Poor communication; unprofessional           |
| 0     | No authorization; major scope violations; unauthorized access | Serious ethical violations; unauthorized damage       | Evidence destroyed; data exfiltrated; no cleanup                | No communication; unprofessional conduct     |

## Submission Requirements

**Due Date:** Friday of Week XX, XX:XX PM

### Deliverables:

1. Executive Summary (PDF)
2. Technical Findings Report (PDF, 8-12 pages)
3. Remediation Roadmap (PDF, 1 page)
4. Appendices (PDF, as needed)
5. Self-assessment reflection (500 words, Word/PDF)

### Submission Format:

- File naming: [Student Name]\_PentestReport\_Week13.pdf
- Single PDF with all sections or clearly labeled folder with PDFs
- Submit via: [Learning management system]

### Self-Assessment Reflection (Required, Ungraded):

In 500 words, address:

1. What was most challenging about conducting this assessment?
  2. How did you ensure you stayed within scope and authorization?
  3. What would you do differently in a real-world penetration test?
  4. How will you use this experience in your career?
  5. What did you learn about social engineering effectiveness?
- 

## Assessment Rubric Summary

| Category                   | Points     | Weight                   |
|----------------------------|------------|--------------------------|
| Content Quality            | 40         | 40%                      |
| Completeness of Testing    | 30         | 30%                      |
| Professional Documentation | 20         | 20%                      |
| Professional Conduct       | 10         | 10%                      |
| <b>TOTAL</b>               | <b>100</b> | <b>2% of Final Grade</b> |

**Passing Grade:** 70/100 (70%)

### Grading Scale:

- A (90-100): Comprehensive, professional-quality report; demonstrates mastery
  - B (80-89): Good quality report; demonstrates solid understanding
  - C (70-79): Adequate report; meets minimum requirements
  - F (<70): Incomplete or inadequate; does not meet requirements
- 

## Important Notes for Students

1. **Authorization is Essential:** All testing must be authorized in writing. Unauthorized access is illegal.
2. **Scope Discipline:** Only test systems explicitly listed in Rules of Engagement. Scope creep can cause real damage.
3. **Evidence Preservation:** Maintain clean documentation of all findings with screenshots, logs, and timestamps.
4. **Professional Conduct:** This project simulates real penetration testing. Treat it as you would a professional engagement.

5. **Team Collaboration:** If working in teams, distribute work clearly and ensure all members understand all findings.
  6. **Confidentiality:** Treat all findings as confidential. Do not share detailed findings outside authorized personnel.
  7. **Ethical Boundaries:** Stay focused on information gathering and demonstration. Do not actually damage systems or steal data.
- 

## Support Resources

- **Instructor Office Hours:** [Schedule]
  - **Security Tools Documentation:** Links provided in course portal
  - **Methodology References:** PTES, NIST CSF, OWASP Testing Guide
  - **Writing Support:** University writing center for report polishing
  - **Technical Support:** Lab environment troubleshooting [contact]
- 

The End!